SOC/UEBA – Báo cáo Dữ liệu, Mô hình và Workflow

UEBA (User and Entity Behavior Analytics): học hành vi bình thường của người dùng và máy, cảnh báo khi hành vi lệch khỏi bình thường – để phát hiện tài khoản bị chiếm và nhân viên nội gián; kết quả đưa vào một SIEM/SOC hoàn chỉnh để điều tra và ứng phó.

1. Dataset đã chọn

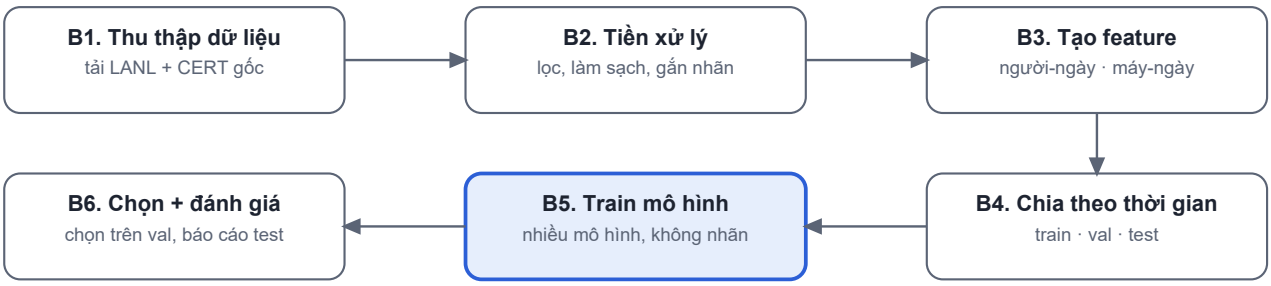
	LANL	CERT r4.2
Tên đầy đủ	Comprehensive, Multi-Source Cyber-Security Events	CERT Insider Threat Test Dataset, bản r4.2
Là dataset về gì	**Hành vi đăng nhập / xác thực** của người dùng và máy tính trong mạng nội bộ một tổ chức lớn: ai đăng nhập, từ máy nào, vào máy nào, bằng cách nào. Dữ liệu **thật**, có ghi lại một cuộc tấn công thật của đội red team.	**Mối đe doạ nội bộ (insider threat)**: hoạt động hằng ngày của nhân viên trên máy tính công ty – đăng nhập, cắm USB, sao chép file, gửi email, duyệt web. Dữ liệu **mô phỏng**, trong đó có một số nhân viên cố ý gây hại.
Dùng để phát hiện	Tài khoản bị kẻ tấn công chiếm và dùng để di chuyển ngang giữa các máy	Nhân viên đánh cắp dữ liệu, cài phần mềm theo dõi, chuẩn bị nghỉ việc và mang dữ liệu đi
Nguồn	Los Alamos National Laboratory (Mỹ), 2015	Carnegie Mellon University – CERT Division, 2013
Link	https://csr.lanl.gov/data/cyber1/	https://kilthub.cmu.edu/articles/dataset/Insider_Threat_Test_Dataset/12841247
Quy mô đã dùng	30 ngày, 508,9 triệu sự kiện đăng nhập, ~26.600 tài khoản người	17 tháng (01/2010 – 05/2011), 32,8 triệu sự kiện, 1.000 nhân viên
Nhãn	749 sự kiện tấn công của red team (181 người-ngày bị tấn công)	70 nhân viên nội gián thuộc 3 kịch bản (966 người-ngày gây hại)

Nhãn chỉ dùng để chấm điểm sau khi train, không dùng để train: hệ thống phải tự phát hiện, đúng như khi triển khai thật (không ai biết trước ai là kẻ tấn công).

2. Workflow của dự án

Dự án gồm hai giai đoạn nối tiếp: **Giai đoạn 1** (B1–B6) chuẩn bị dữ liệu và train mô hình phát hiện bất thường – làm một lần, offline. **Giai đoạn 2** (B7–B15) đưa mô hình đã train vào một hệ thống **SIEM/SOC**: mỗi ngày log mới được nạp, phát hiện bằng luật + ML, gom thành incident, playbook tự điều tra, con người kết luận và ứng phó.

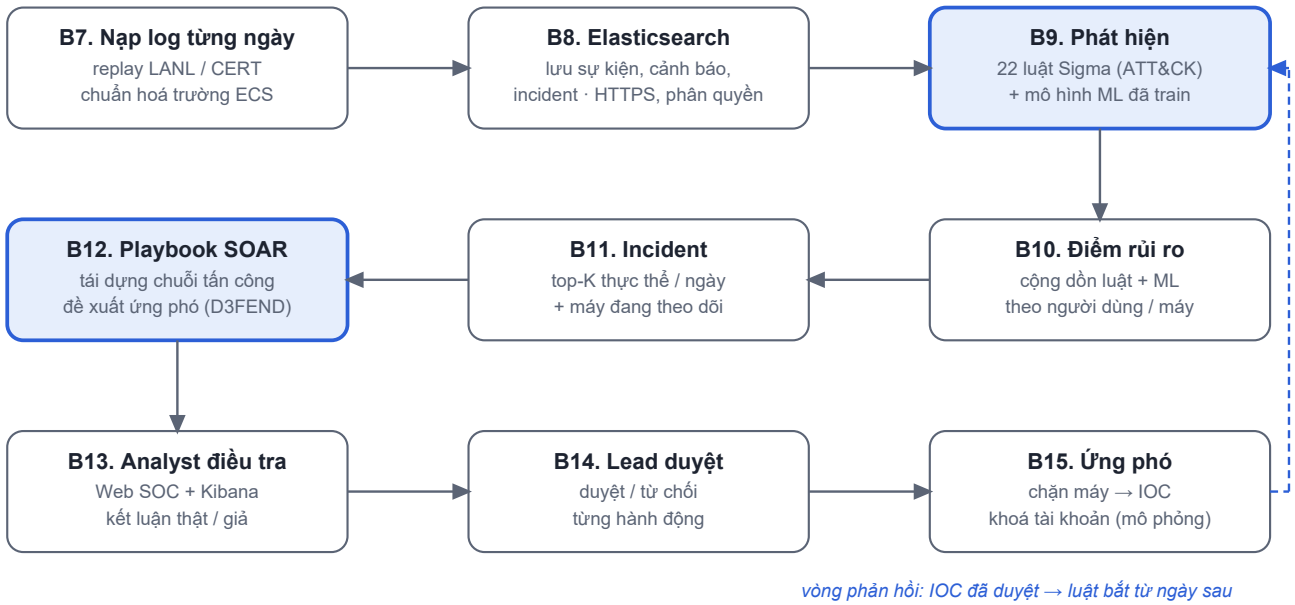
2.1. Giai đoạn 1 – Dữ liệu và train mô hình



Bước	Làm gì	Đầu ra
B1. Thu thập	Tải dữ liệu gốc từ trang chính thức (LANL 30 ngày đầu, CERT r4.2 + file đáp án). Không tự tạo dữ liệu.	Log gốc
B2. Tiền xử lý	LANL: đọc thẳng file nén, cắt theo ngày, tách loại tài khoản (người / máy / hệ thống). CERT: đọc 5 loại log, rút gọn 14 GB web theo domain, làm giàu (ngoài giờ, email ra ngoài, danh mục web). Gắn nhãn – chỉ để chấm điểm. Chi tiết ở mục 3.	Bảng sự kiện sạch (parquet)
B3. Tạo feature	Tóm tắt hành vi mỗi người dùng mỗi ngày thành các con số, so với chính lịch sử của họ (vd. số máy mới đăng nhập vào, cắm USB ngoài giờ). LANL thêm feature theo máy nguồn.	LANL 41 feature · CERT 56 feature
B4. Chia thời gian	Học quá khứ, kiểm tra tương lai: train → validation → test (test không được nhìn khi thiết kế).	3 giai đoạn (mục 3.4)

Bước	Làm gì	Đầu ra
B5. Train	Train nhiều mô hình không giám sát trên giai đoạn train (chi tiết từng dataset ở mục 4).	Mô hình đã train
B6. Chọn + đánh giá	Chọn mô hình và tham số tốt nhất trên validation; chạy một lần trên test để báo cáo.	Mô hình cuối + kết quả

2.2. Giai đoạn 2 – Xây SIEM/SOC sau khi train xong



Mỗi ngày chạy lại B7 → B15 (demo: replay giai đoạn test, bấm "Ngày tiếp theo" trên web)

Bước	Làm gì	Công nghệ
B7. Nạp log	Mỗi ngày nạp log của ngày đó (demo: phát lại giai đoạn test từng ngày), chuẩn hoá về trường ECS và làm giàu: loại tài khoản, nguồn ≠ đích, ngoài giờ, độ phổ biến domain.	Python (pandas, pyarrow)
B8. Lưu trữ	Lưu sự kiện, cảnh báo, incident, IOC, nhật ký kiểm toán; tra cứu khi điều tra.	Elasticsearch + Kibana 9.5 (HTTPS, user quyền tối thiểu)
B9. Phát hiện	Hai lớp song song: **luật Sigma** bắt mẫu tấn công đã biết (Pass-the-Hash, dò mật khẩu, chép dữ liệu ra USB…, gắn MITRE ATT&CK) và **mô hình ML** của giai đoạn 1 bắt hành vi lạ chưa có luật.	22 luật Sigma (11 luật nền + 11 luật tương quan sinh cảnh báo), engine tự viết; mô hình mục 4
B10. Điểm rủi ro	Cộng dồn điểm luật + ML theo từng người dùng / máy, giảm dần theo thời gian; luật hay báo nhầm bị giảm trọng số.	Python
B11. Incident	Mỗi ngày lấy K thực thể rủi ro cao nhất (LANL: 20 tài khoản + 5 máy + máy đang theo dõi; CERT: 5 nhân viên) → incident, xếp mức critical / high / medium.	Python → ES
B12. Playbook SOAR	Tự chạy cho mỗi incident: **tái dựng chuỗi tấn công** (LANL: đồ thị đăng nhập → máy bàn đạp, tài khoản bị chiếm, máy bị chạm tới; CERT: dòng thời gian theo pha) rồi **đề xuất ứng phó**, mỗi hành động gắn biện pháp MITRE D3FEND.	soc/graph, soc/playbooks
B13. Điều tra	Analyst xem incident, bằng chứng, đồ thị chuỗi tấn công, MITRE; ghi kết luận (tấn công thật / hợp lệ / báo động giả).	Web SOC (FastAPI) + Kibana
B14. Duyệt	Lead duyệt hoặc từ chối từng hành động playbook đề xuất; mọi thao tác ghi nhật ký kiểm toán chỉ-thêm.	Phân quyền analyst / lead
B15. Ứng phó	Chặn máy nguồn → máy vào danh sách IOC → luật Sigma IOC tự bắt mọi đăng nhập từ máy đó từ ngày sau (vòng phản hồi). Khoá tài khoản, chặn USB: mô phỏng.	Luật Sigma IOC

Kế hoạch build và trạng thái

Thành phần	Trạng thái
Elasticsearch + Kibana bật bảo mật; nạp log, cảnh báo, incident	Đã xong
22 luật Sigma (11 nền + 11 tương quan), gắn MITRE ATT&CK; ngưỡng chọn trên train	Đã xong
ML chấm điểm hằng ngày; điểm rủi ro + incident (hàng đợi tài khoản + máy)	Đã xong
Playbook SOAR: chuỗi tấn công LANL, dòng thời gian CERT, ứng phó gắn D3FEND	Đã xong, có chấm điểm (mục 4.3)
Web SOC: hàng đợi, bằng chứng, đồ thị, kết luận, duyệt, IOC, kiểm toán, phân quyền	Đã xong (kiểm thử 17/17)
Demo vận hành từng ngày + vòng phản hồi IOC	Đã xong (replay)
AI Agent LLM (Qwen3 4B chạy trên máy)	Đã thử, bỏ: kết luận đúng 9/20, kém cả mốc đơn giản 14/20
Thu log trực tiếp từ máy thật (Winlogbeat)	Không làm: replay có nhãn để đánh giá

3. Tiền xử lý dữ liệu

Log gốc có hàng trăm triệu sự kiện, mô hình không đọc trực tiếp được. Tiền xử lý biến log thành **một dòng số liệu cho mỗi người dùng mỗi ngày** (người-ngày), mô tả hành vi của họ so với chính quá khứ của họ. Bốn nguyên tắc xuyên suốt:

Nguyên tắc	Nghĩa là
Không tự tạo dữ liệu	Chỉ dùng log gốc tải từ trang chính thức (LANL, CMU KiltHub).
Nhãn chỉ để chấm điểm	Nhãn tấn công được gắn vào bảng nhưng không bao giờ là đầu vào của mô hình hay luật – hệ thống phải tự phát hiện.
Chỉ nhìn quá khứ	Mọi feature "so với lịch sử" ở ngày d chỉ dùng dữ liệu trước ngày d – giống hệ thống thật chạy từng ngày, không biết trước tương lai.
Không loại ngoại lai	Hành vi lạ chính là thứ cần tìm; chỉ giảm ảnh hưởng của giá trị cực đoan (log, làm mượt, giới hạn z-score) chứ không xoá.

3.1. LANL – log đăng nhập (≈ 1 tỷ dòng)

Bước	Làm gì	Vì sao
1. Đọc theo luồng	Đọc thẳng file nén 7,6 GB theo khối 64 MB (pyarrow), cắt theo ngày (thời điểm ÷ 86.400), ghi mỗi ngày một file parquet (~17–23 triệu sự kiện/ngày).	Không cần giải nén ra đĩa, RAM chỉ 1–2 GB
2. Gắn nhãn chính xác	Sự kiện là tấn công khi khớp **đủ 4 trường** (thời điểm, tài khoản, máy nguồn, máy đích) với file red team.	Không gắn nhầm cho sự kiện bình thường cùng giây
3. Phân loại tài khoản	Theo tên: người (U…@DOM), máy (có $@), hệ thống (SYSTEM@, LOCAL SERVICE@…). Chỉ phân tích tài khoản người: 301.462 người-ngày (máy 295.751, hệ thống 232.400).	Kẻ tấn công dùng tài khoản người bị đánh cắp
4. Tổng hợp theo ngày	Khối lượng (số sự kiện, số máy nguồn/đích), kiểu xác thực (tỉ lệ thất bại, NTLM, Kerberos, từ xa, từng loại logon), nhịp thời gian (số giờ hoạt động, entropy theo giờ, giờ đầu/cuối, khoảng cách giữa sự kiện, tối đa/phút).	Tóm hàng nghìn sự kiện thành vài chục con số
5. Làm mượt tỉ lệ	Mỗi tỉ lệ được kéo về trung bình chung bằng 20 "sự kiện ảo".	Tài khoản có 1–2 sự kiện dễ ra 0% / 100% → báo nhầm
6. Mới lạ so với chính mình	Máy nguồn/đích lần đầu dùng, giờ lạ, đường đi máy A → máy B chưa ai dùng, đăng nhập NTLM từ máy mới, số tài khoản dùng chung một máy nguồn mới (fan-in).	Tín hiệu di chuyển ngang, Pass-the-Hash
7. Độ hiếm có suy giảm	Thay cờ "đã thấy / chưa thấy" bằng số đếm giảm một nửa sau 7 ngày; độ hiếm = −log(tần suất); mỗi ngày lấy giá trị **hiếm nhất**.	Cờ bị "đầu độc": kẻ tấn công dùng máy một lần là máy thành quen mãi
8. Chống đầu độc baseline	Người-ngày đã bị cảnh báo không được học vào lịch sử "bình thường" (cách ly).	Hành vi nghi ngờ không trở thành chuẩn mới

Bước	Làm gì	Vì sao
9. Chuẩn bị đầu vào	Bỏ cột trùng (n_logon tương quan 0,97 với n_events) và gần như hằng; cột đếm biến đổi log(1+x); chuẩn hoá theo giai đoạn train → **41 feature**.	Phân bố đếm lệch nặng; cột trùng làm méo mô hình
10. Feature mức máy	Theo (máy nguồn, ngày): số tài khoản người mà với họ máy là lạ, trong đó bao nhiêu đăng nhập NTLM.	Đầu vào cho phát hiện máy bàn đạp

3.2. CERT r4.2 – hoạt động nhân viên (5 loại log, ~33 triệu sự kiện)

Bước	Làm gì	Vì sao
1. Đọc 5 loại log	Logon (855 nghìn), USB (405 nghìn), file chép ra USB (446 nghìn), email (2,6 triệu), web (14 GB – đọc theo luồng, **bỏ cột nội dung trang**).	Chỉ giữ thông tin hành vi, giảm dung lượng
2. Rút gọn web	Gom 14 GB lịch sử web thành bảng (nhân viên, ngày, domain, số lượt vào).	Đủ nhỏ để xử lý, vẫn giữ được domain
3. Làm giàu sự kiện	Ngoài giờ (trước 8h / sau 18h), cuối tuần; đuôi file chép ra USB (.exe, .zip, .doc); email ra ngoài công ty (người nhận không thuộc dtaa.com) và có đính kèm; danh mục web: tuyển dụng, đối thủ (như bộ lọc URL của proxy).	Biến sự kiện thô thành dấu hiệu có nghĩa
4. Độ hiếm domain	Bao nhiêu % nhân viên **đã từng** vào domain đó **trước** hôm nay; dưới 1% = cực hiếm. Không dùng nhãn.	Trang lạ (wikileaks, bán keylogger) tự nổi lên
5. Tổng hợp người-ngày	Đăng nhập, USB, file, email, web, độ hiếm domain – 330.452 người-ngày.	Đơn vị phân tích chung
6. Cửa sổ thời gian	Tổng 7 ngày và 30 ngày của mỗi hành vi (chỉ quá khứ).	Kịch bản lấy dữ liệu dần dần: từng ngày trông bình thường
7. Xu hướng	30 ngày gần nhất so với mức trung bình 60 ngày trước đó.	Bắt nhân viên tăng dần việc chép dữ liệu trước khi nghỉ
8. Độ lệch so với chính mình	So mỗi chỉ số với trung bình và độ lệch chuẩn các ngày trước của chính nhân viên (z-score), giới hạn [−10, 10] → 56 feature + 56 độ lệch = 112 con số. Thêm bước này làm PR-AUC của Autoencoder tăng gấp đôi (0,045 → 0,091).	Mỗi người có thói quen riêng – so với chính họ
9. Bỏ cột trùng, biến đổi	Bỏ 3 cột tương quan > 0,95 (logoff ~ số máy 0,99; file .doc ~ tổng file 0,996; email ~ web 0,97); cột đếm log(1+x); chuẩn hoá.	Tránh đếm trùng một thông tin
10. Khởi động (warm-up)	Những tuần đầu chỉ làm lịch sử, không đưa vào train.	Độ hiếm và z-score chưa ổn định khi quá ít quá khứ
11. Gắn nhãn đúng người	Chỉ giữ sự kiện của chính insider trong khoảng ngày của họ: 70 insider, 966 người-ngày độc hại.	Kịch bản 3 mạo danh sếp – sếp là nạn nhân, không gắn nhãn xấu

3.3. Kiểm tra chất lượng dữ liệu (trước khi train)

Kiểm tra	LANL	CERT r4.2
Giá trị thiếu	Không có	Không có
Bản ghi trùng	–	Không trùng ID; 6 dòng USB trùng nội dung (không đáng kể)
Ngày lỗi / ngoài khoảng	Không có (ngày 57 chưa trọn → bỏ)	Không có
Cột tương quan > 0,95	n_events ~ n_logon (0,97) → bỏ n_logon	3 cặp → bỏ logoff_n, file_doc, email_n
Tỉ lệ nhãn tấn công	0,06% người-ngày (181)	0,29% người-ngày (966)
Ngoại lai (quy tắc 3×IQR)	19–25% ở tỉ lệ thất bại, fan-in – giữ lại	17% ở số lần cắm USB – giữ lại

Mất cân bằng cực mạnh (0,06% và 0,29%) là lý do dùng học không giám sát và đánh giá bằng PR-AUC thay vì accuracy. Sau tiền xử lý, tín hiệu tấn công đã rõ: ở LANL, số đăng nhập NTLM từ máy mới của người bị tấn công trung bình gấp 58 lần người bình thường; số đường đi chưa ai dùng từ máy mới gấp 28 lần.

3.4. Chia dữ liệu theo thời gian

	Train (học)	Validation (chọn mô hình)	Test (báo cáo)
LANL	ngày 1–7	ngày 8–19	ngày 20–29
CERT	02–06/2010 (sau warm-up)	07–08/2010	09/2010 – 05/2011

Học quá khứ, kiểm tra tương lai; tập test chưa từng dùng khi thiết kế. LANL ngày 30–56 tải thêm sau khi đã train xong – không có nhãn, chỉ dùng cho demo vận hành trên dữ liệu mới.

4. Mô hình dùng cho từng dataset

Tất cả là học **không giám sát**: mô hình chỉ học hành vi **bình thường** từ giai đoạn train, rồi chấm mỗi người-ngày một điểm bất thường, quy về thang 0–1 so với train (0,99 = bất thường hơn 99% người-ngày lúc train).

4.1. LANL – phát hiện tài khoản bị chiếm và di chuyển ngang

	LANL
Chia dữ liệu	Train ngày 1–7 (69.205 người-ngày) · validation ngày 8–19 (110.807, 97 tài khoản bị chiếm) · test ngày 20–29 (110.381, 26 tài khoản bị chiếm)
Feature (41)	Số máy đăng nhập vào / từ, máy nguồn / đích mới so với lịch sử, đăng nhập NTLM từ máy lạ, đường đi mạng chưa ai dùng, số tài khoản dùng chung máy nguồn (fan-in), giờ lạ, nhịp thời gian…

LANL dùng những gì và mỗi thứ hoạt động thế nào:

Thành phần	Hoạt động thế nào
1. Độ hiếm có tần suất	Với mỗi người dùng, đếm số lần đã đăng nhập từ / vào từng máy, số đếm **giảm dần** theo thời gian (giảm một nửa sau 7 ngày). Máy chưa từng dùng hoặc lâu rồi không dùng → độ hiếm cao. Lấy giá trị hiếm nhất trong ngày làm feature.
2. ECOD	Với từng feature, tính xác suất gặp một giá trị lớn như vậy trong dữ liệu train (vd. chỉ 0,1% người-ngày đăng nhập vào hơn 50 máy), cộng độ hiếm của mọi feature lại. **Càng nhiều chỗ hiếm = càng bất thường**; chỉ ra được feature nào gây cảnh báo. Không có tham số cần chỉnh.
3. Isolation Forest (nhóm feature di chuyển ngang)	300 cây, mỗi cây cắt dữ liệu ngẫu nhiên theo từng feature. Hành vi bình thường nằm giữa đám đông nên phải cắt nhiều lần mới tách riêng được; hành vi lạ nằm lẻ loi nên vài nhát đã bị tách. **Càng ít nhát cắt = càng bất thường.** Chỉ dùng các feature di chuyển ngang để tín hiệu tấn công không bị loãng.
4. Điểm tài khoản	Trung bình điểm percentile của ECOD và Isolation Forest.
5. Chấm điểm từng ngày + cách ly	Chạy như thật: hôm nay chấm điểm xong mới đưa vào lịch sử. Người-ngày đã bị cảnh báo **không** được học làm "bình thường" – nếu không, kẻ tấn công quay lại máy cũ hôm sau sẽ bị coi là quen (đầu độc lịch sử).
6. Phát hiện máy bàn đạp (theo máy)	Mỗi máy mỗi ngày: đếm số tài khoản đăng nhập NTLM từ máy đó mà với chính họ máy đó là lạ, so với tỉ lệ trung bình toàn mạng bằng phân phối Poisson. Máy cá nhân thường chỉ có 1–2 người dùng quen; một máy bỗng có hàng chục tài khoản lạ = kẻ tấn công dùng mật khẩu đánh cắp.
7. Hàng đợi cho analyst	Mỗi ngày: 20 tài khoản rủi ro cao nhất (luật + ML) + 5 máy bàn đạp đáng ngờ nhất + máy đã bị nghi trong 7 ngày qua xuất hiện lại. Incident máy liệt kê mọi tài khoản đăng nhập từ máy đó (máy ≤ 50 tài khoản).

Bước cải tiến (LANL)	Bắt được (test)	Vì sao
Ban đầu: thống kê + IF + Autoencoder	0/26	Gộp 3 mô hình làm loãng tín hiệu tấn công
ECOD + IF trên nhóm feature di chuyển ngang	1/26	Tập trung đúng nhóm feature tấn công
+ chống "đầu độc lịch sử" + độ hiếm có tần suất	4/26	Kẻ tấn công dùng lại máy cũ nên mô hình đã quen; sửa để máy đó vẫn bị coi là lạ
+ phát hiện máy bàn đạp (xét theo máy)	22/26	Kẻ tấn công dùng 1 máy đăng nhập hàng chục tài khoản – xét theo máy thì rất lộ

Bước cải tiến (LANL)	Bắt được (test)	Vì sao
+ theo dõi máy đã bị nghi trong 7 ngày	**26/26**	Bắt cả những ngày máy đó chỉ đăng nhập 1–2 tài khoản (~39 incident/ngày)

Cùng ngân sách xem của analyst. Hai bước cuối được thiết kế sau khi phân tích các tài khoản bị sót trên tập test nên báo cáo tách riêng; trên đợt tấn công đầu (validation) chúng bắt 96/97 tài khoản. Xếp hạng tài khoản trên test: ROC-AUC 0,971, PR-AUC 0,087 (gấp ~283 lần đoán mò).

4.2. CERT r4.2 – phát hiện nhân viên nội gián

	CERT r4.2
Chia dữ liệu	Train 02–06/2010 (106.343 người-ngày) · validation 07–08/2010 (42.193, 24 nội gián) · test 09/2010 – 05/2011 (161.367, 52 nội gián)
Feature (56)	Đăng nhập / USB / file / email / web ngoài giờ, domain web hiếm trong công ty (tính từ các ngày trước, không dùng nhãn), trang tuyển dụng, trang đối thủ, tổng hành vi 7 và 30 ngày, xu hướng 30 ngày gần nhất so với 2 tháng trước.

CERT dùng những gì và mỗi thứ hoạt động thế nào:

Thành phần	Hoạt động thế nào
1. Độ lệch so với chính mình	Mỗi feature được so với thói quen của chính nhân viên đó (z-score theo lịch sử cá nhân) → 56 feature gốc + 56 độ lệch = 112 con số / người-ngày.
2. Isolation Forest	Như ở LANL (300 cây, đếm số nhát cắt để tách một người-ngày). Bắt tốt hành vi **đột biến**: một ngày bỗng cắm USB lúc nửa đêm và vào trang lạ.
3. Autoencoder (mạng nơ-ron)	Nén 112 con số xuống còn 8 rồi dựng lại (112→32→8→32→112). Chỉ học hành vi bình thường nên dựng lại hành vi bình thường rất sát nhưng dựng sai hành vi lạ. **Sai số dựng lại càng lớn = càng bất thường.** Bắt được tổ hợp lạ mà từng con số riêng lẻ vẫn bình thường (vd. lấy dữ liệu dần dần trước khi nghỉ việc).
4. Bagging + kết hợp	Mỗi mô hình train 3 lần với seed khác nhau rồi lấy trung bình (giảm dao động), sau đó trung bình điểm IF và AE. Chọn cách kết hợp này trên validation.
5. Hàng đợi cho analyst	Cộng với luật Sigma thành điểm rủi ro, mỗi ngày 5 nhân viên rủi ro cao nhất thành incident.

Mô hình (CERT)	ROC-AUC	PR-AUC	Bắt nội gián (5 cảnh báo/ngày)	Nhận xét
Thống kê (độ lệch z-score)	0,859	0,015	10/52	Chỉ so từng con số riêng lẻ – yếu
ECOD	0,903	0,021	6/52	Nội gián thường lệch nhẹ nhiều chỗ, không cực trị ở 1 chỗ – yếu
Isolation Forest	0,960	0,070	35/52	Tốt với hành vi đột biến (kịch bản 1, 3)
Autoencoder	0,946	0,095	45/52	Bắt tốt hành vi lấy dữ liệu dần dần (kịch bản 2)
IF + AE (đã chọn)	0,959	0,092	41/52	Ổn định nhất giữa các lần train → chọn

Trung bình 3 lần train, cùng bộ feature, đo trên tập test. Kết quả cuối ở ngưỡng 0,99: bắt 42/52 nội gián, ~5,4 cảnh báo/ngày cho 1.000 nhân viên; theo kịch bản: đánh cắp qua USB + web 22/22, lấy dữ liệu dần trước khi nghỉ việc 15/25, cài keylogger 5/5.

4.3. Sau khi phát hiện – tái dựng chuỗi tấn công (bước B12)

Mô hình chỉ nói *ai* bất thường. Playbook SOAR trả lời tiếp *kẻ tấn công đã đi đến đâu* để ứng phó đủ phạm vi – chỉ dùng dữ liệu tới ngày của incident, không dùng nhãn.

	Hoạt động thế nào	Kết quả (test)
LANL – đồ thị đăng nhập	Dựng đồ thị tài khoản → máy nguồn → máy đích. Từ máy bàn đạp của incident (hoặc máy nguồn lạ của tài khoản), lấy mọi đăng nhập từ xa **không quen** (cặp tài khoản–máy dùng < 10 ngày trước đó) → tài khoản bị chiếm, máy bị chạm tới; máy khác dùng chung ≥ 3 tài khoản bị chiếm cũng là máy tấn công. Tính thêm bán kính ảnh hưởng.	Tìm **98,8%** tài khoản bị chiếm và 92,9% máy bị chạm tới (val 98,7% / 99,6%); 53% tài khoản trong chuỗi có nhãn red team. Incident tài khoản U66, U737 tự lần ra máy bàn đạp C17693.
CERT – dòng thời gian theo pha	Xếp hành vi trong khoảng incident vào 4 pha: Truy cập → Chuẩn bị → Cài đặt → Đánh cắp; đánh dấu bước **MỚI** so với 30 ngày trước của chính nhân viên.	Incident nội gián thật có bước đánh cắp MỚI: **59%**; incident lành tính: 9,5%
Đề xuất ứng phó	Mỗi hành động gắn kỹ thuật ATT&CK nó chặn và biện pháp MITRE D3FEND (lấy từ ánh xạ chính thức), vd. chặn máy nguồn = D3-NTF, khoá tài khoản = D3-AL, chặn USB = D3-IOPR.	Lead duyệt; chặn máy → IOC thật

Tham số tái dựng chuỗi chọn trên validation. Precision ~50% là cận dưới: nhãn red team LANL chỉ đánh dấu một phần sự kiện, và không tài khoản nào dùng máy C17693 thường xuyên.

5. Những điểm cần lưu ý

• **Đã sửa lỗi rò nhãn:** bản đầu của CERT dùng danh sách trang web lấy từ chính file nhãn (kết quả đẹp giả); đã thay bằng độ hiếm domain tính từ dữ liệu, không dùng nhãn.
• **LANL ban đầu được đánh giá trên dữ liệu đã nhìn:** khi kiểm tra trên 10 ngày hoàn toàn mới, mô hình ban đầu gần như không phát hiện được – các bước cải tiến ở mục 4.1 ra đời từ đó.
• **Bỏ AI Agent:** mô hình ngôn ngữ chạy trên máy kết luận đúng 9/20 incident, kém cách đơn giản "critical → tấn công" (14/20) và không kiểm chứng được → thay bằng playbook tất định ở B12.
• **Hạn chế:** tập test nhỏ (26 tài khoản, 52 nội gián); CERT là dữ liệu mô phỏng nên kết quả có thể lạc quan hơn thực tế; playbook LANL đề xuất chặn máy ở cả incident lành tính – cần lead duyệt; máy tấn công phụ chỉ dùng 1 tài khoản bị chiếm (C19932) chưa được tìm ra.